



# Managing Risk @ KPMG

**Non-client** facing External Consultants

March 2021

---

[kpmg.ch](https://kpmg.ch)

# Managing Risk at KPMG

## **We are glad you are about to start working with KPMG!**

While you are working with us, we expect you to adhere to the same high standards that apply to our own staff. This includes knowing our Swiss Code of Conduct and acting with integrity.

You don't have to be an expert in regulations or policy but you do need to consult with us if you find yourself in a difficult situation, or you suspect some wrong-doing. The risks of non-compliance are real: for you, your firm and KPMG.

By behaving ethically and ensuring the highest standards you can manage these risks successfully. The information contained in this pack provides an overview of what is important for you to know.

- How regulation affects the business we work in and how this impacts you personally
- The key policies/guidelines you must comply with
- The channels available to you if you need advice or have to report a concern
- Your responsibility and the commitment required to meet the highest principles of ethics and integrity through personal behaviours that are consistent with KPMG's Code of Conduct

Before you begin with KPMG you are required to read this pack and return the accompanying declarations to KPMG.

## **Important:**

**Please ensure you complete and return the [Compliance Confirmation](#)**

# We work in a regulated environment

Our work is under constant scrutiny by regulators who act in the public interest to ensure that KPMG and similar firms have high standards of professional work. There are strict rules about the quality of our work, what we can and cannot do; and with whom we can and cannot work.

## Your responsibilities

### Risk management is everyone's responsibility.

The ability to identify potential risks and take steps to appropriately mitigate those risks is central to effective risk management, as is compliance with the policies and protocols we have put in place.

Understanding by all our people about the importance of risk management in meeting our professional obligations is critical to our business.

All of us are personally responsible for following the legal, professional, and ethical standards that apply to our individual roles and responsibilities.

- **Stay informed** about laws, professional standards and KPMG policies that apply to you and your work
- **Stand firm** if you encounter pressure to act in a way that compromises KPMG values
- **Conduct** your personal affairs in a manner that is consistent with the code
- **Speak up** if something doesn't seem right
- **Consult with others** when in doubt and to make the best decisions

## Compliance with our Code

- KPMG, our clients, our regulators and the public expect compliance with the regulations that govern our profession. Non-compliance exposes KPMG to legal, regulatory and reputational risks
- Behaviour inconsistent with our Code is unacceptable and could ultimately lead to termination of a contract
- Failure to raise issues is also unacceptable. If you have suspicions about unethical or illegal behaviour or behaviour otherwise not compliant with our standards either by KPMG, its clients or your firm, you have a responsibility to report it promptly
- Individuals that report in good faith will not suffer any detriment, regardless of whether or not the concern is ultimately substantiated

- Standards are high and failure to comply with these rules is not an option. There is no margin for error as consequences are immediate and can be severe
- The rules are put in place to protect those who use our services and rely on our work to be accurate, objective, and truthful

For further information, the KPMG Code of Conduct is available online at [Swiss Code of Conduct](#)



# Ethics and Independence

- Swiss Code of Conduct – Ethical Culture and KPMG
- Independence Considerations

# Swiss Code of Conduct – Ethical Culture and KPMG

Our [Swiss Code of Conduct](#) sets out principles and guidance to help you understand the ethical behaviours expected of everyone who works for KPMG.

Everything we do is underpinned by a shared set of values that define how we work together, with our clients, with people and with communities – globally.

## This is what we believe in:

- **Integrity:** We do what is right.
- **Excellence:** We never stop learning and improving.
- **Courage:** We think and act boldly.
- **Together:** We respect each other and draw strength from our differences.
- **For better:** We do what matters.

## These are our values

## Ethical Decision Making

The vast majority of us strive to ‘Do the right thing’ and maintain high ethical standards.

Deciding right from wrong is easy when the situation is simple and straightforward. Complex situations require more consideration especially when you are faced with an ethical dilemma. Two or more responses to a situation could be justified, and the differences between right and wrong may be subtle or subjective.

Recognising these situations is your responsibility.

When you are faced with unclear situations:

- Find out if there are any rules, regulations, professional standards and KPMG policies to help you – as compliance with these is mandatory
- Consider your personal biases and perspectives
- Look at the personal, professional, and business perspectives
- Consult with others appropriately
- Consultation is a sign of strength, not weakness

KPMG’s ethical culture is critical to our long-term business success. Our values are our permanent driving force and give us a moral compass to navigate through everything we do. They define our ethical culture and what KPMG stands for – and they underpin our Code.

Our ethical culture draws its strength from everyone who works at KPMG – including you. We are all committed to upholding our values – it is your personal responsibility.

Compromising our standards of behaviour is unacceptable.

# Independence Considerations

## Personal Independence

The independence rules apply to us personally because our regulators, the public, our clients and the profession want to avoid any personal circumstances affecting, or being perceived to affect, the work that KPMG does.

## Why do Independence Rules exist?

Firms like KPMG are governed by regulators who set standards to protect clients and the public – which means there are specific standards we must meet while going about our work. Part of KPMG's business is to audit the financial statements of other businesses. Users of these financial statements want to know whether the reports can be relied on. But to do this, we have to give an unbiased and professional opinion – to be objective – and that means we (i.e. KPMG and everyone who works for KPMG) have to be independent.

## Independence matters for External Consultant too

As a External Consultant engaged by KPMG for a specific period of time or for a specific project **in a non-client facing role** the independence rules will normally not be directly applicable to your activities. However, if your role at KPMG changes to involve client service, the independence rules would be relevant and appropriate actions (such as additional training) must be taken at the time of the change.

Furthermore, even in a **non-client facing role** activities such as acting as a company director or employee of any KPMG audit client will result in a breach of our independence requirements.

You must therefore disclose such relationship to us.

For questions or to request further information please contact Ethics & Independence Partner (Tara Collins Vieli at [taracollins@kpmg.com](mailto:taracollins@kpmg.com) or +41 58 249 54 41)

# There are Consequences for Everyone

**There are consequences for everyone if you, your colleagues or the Firm do not comply with the independence policies.**

**For you personally:**

- You may be removed from the KPMG engagement and your contract may be terminated with the Firm
- You may be subject to disciplinary action by any professional body of which you are a member
- You may be given a personal fine by the regulators
- You may have to dispose of investments-possibly at a loss

**For KPMG:**

- The Firm's reputation can be damaged
- The Firm may be investigated by the regulators
- Fines can be imposed by the regulators
- Client(s) may choose to end their working relationship with KPMG
- KPMG may lose other/future work from existing and potential clients

**The impact of getting it wrong is severe which is why KPMG has a zero tolerance policy for failure.**

**Your valuable reputation is at stake along with KPMG's and your firm's, so please take responsibility for helping us to get independence right.**



# Policies/Guidance

When working at KPMG you must comply with our policies at all times. In addition to our independence policies, this section outlines the principles of the key policies that you are required to comply with:

- Anti Bribery, Corruption and Fraud
- Insider Trading
- Privacy
- Whistleblowing
- Acceptable Use of Assets

Appendix  
Privacy Policy

# Anti-Bribery, Corruption and Fraud

KPMG has zero tolerance for any form of bribery, corruption and fraud. Such inappropriate conduct could include facilitation payments, favouritism, reciprocity or inappropriate gifts and entertaining.

We are committed to conducting business fairly and ethically, and avoiding even the perception that KPMG or anyone who works for KPMG would engage in inappropriate conduct to obtain an advantage or cause a loss.

Bribery (in all its forms) is illegal, unethical, unacceptable and inconsistent with our Code of Conduct and Values – even if the activities and behaviors are permitted or tolerated in other parts of the world. Where you see or suspect that someone at KPMG, at a client or anyone else you deal with professionally is involved in bribery, you must report it immediately.

## Remember

- Be careful that offering or receiving gifts and entertainment doesn't cast doubt on KPMG's or your own integrity, independence, objectivity or judgment
- Bribery, corruption or fraud (in all their forms) are illegal, unethical, unacceptable and inconsistent with our Code of Conduct and Values
- Where you see or suspect that someone at KPMG, at a client or anyone else you deal with professionally is involved in bribery, fraud and corruption, you must report it immediately

## Report to:

- Ethics & Independence Partner - Partner (Tara Collins Vieli at [taracollins@kpmg.com](mailto:taracollins@kpmg.com) or +41 58 249 54 41)
- Quality & Risk Management Partner (Philipp Hallauer at [phallauer@kpmg.com](mailto:phallauer@kpmg.com) or +41 58 249 41 97)
- Head of OGC (Office of the General Counsel) at [pfatzer@kpmg.com](mailto:pfatzer@kpmg.com) or +41 58 249 41 95)

## Consequences of Non-Compliance

- Violations of anti-bribery and anti-corruption laws can result in significant civil and criminal penalties
- The damage to the reputations of KPMG, our clients, your firm and you personally of getting things wrong is often severe as when cases become public they can attract significant and damaging media and public attention
- There are, additionally, potential personal costs for failure by you to comply with our anti-bribery, anti policies, including intense personal scrutiny-being interviewed and subject to forensic investigation

**Don't take the risk! If you have any suspicions, report them.**

# Insider Trading

You are prohibited by law and by KPMG policy from insider trading.

Insider trading is where you trade or deal in (or procure someone to trade) in a financial product while you have inside information, or where you communicate inside information to a third party.

If inside information is leaked to the media or other external sources, there could additionally be significant financial and reputational impact on the client as well as on KPMG.

## Remember

Working with KPMG will result in you being privy to inside information which you must never use (either yourself directly or to assist others).

If you have the following information and either:

- You know or you ought to know that the information is not generally available to others; or
- In the event the information were generally known to others, people would expect the information to have a material effect on the price or value of a financial product

Then you are an “Insider”. As an Insider, **you must not:**

- apply for, acquire or dispose of the financial product, or enter into an agreement to do any of those things; or
- procure another person who does any of those things in relation to the financial product.

In addition to the general prohibition, you must not deal in financial products of any KPMG client or other specified party that is part of, or involved in, an engagement in which you are involved or which you are aware of until the later of:

- KPMG completes providing, or ceases to provide, services on the engagement; or
- until all inside information in your possession in relation to such parties is considered public information or is generally available

## Consequences of Non-Compliance

As well as potentially serious civil and criminal liability, an insider trading is a serious breach of the conditions of your relationship with KPMG and will lead to disciplinary action, including possible dismissal.

For questions or to request further information, please contact National Quality Risk Management team at [CH-FMNORM@kpmg.com](mailto:CH-FMNORM@kpmg.com)

# Privacy

KPMG is governed by the *Federal Act on Data Protection and, to the extent applicable, the EU GDPR* which provides for the protection of an individual's personal information. It establishes certain **Privacy Principles** to regulate the handling of personal information, with special rules around the handling of sensitive information. The way we manage privacy is set out in the **KPMG Privacy Policy** which is available in the Appendices.

## Handling Personal and Sensitive Information

There are a few key things you need to remember when dealing with personal and sensitive information:

- Transparency: KPMG will provide individuals with information about how we process their Personal Information to the extent necessary to ensure that processing is fair, we can only collect personal information if it is necessary to undertake the engagement activity.
- Purpose Limitation: We must only collect the information for a specific purpose and we must only use the information for that specific purpose.
- Data quality and proportionality: We should regularly review the information we hold to make sure it is accurate and up-to-date. Personal data we hold must be adequate, relevant and not excessive
- Security and Confidentiality: Reasonable precautions must be taken to secure personal data against accidental or unlawful destruction or loss, alteration, unauthorized disclosure or access.
- Access, Rectification, Deletion and Objection: Individuals should have access to their personal data that is held by us, they also have a right to rectification, deletion and objection, where those requests are reasonable and permitted by law or regulation.
- Sensitive Data: Where we process sensitive personal data, we will take such additional measures as are necessary to protect that data.
- Data Used for Marketing Purposes: Where personal data is processed for the purposes of direct marketing, effective procedures should exist allowing the person at any time to "opt-out" from having their data used for such purposes.
- Automated Processing: Where personal data is processed on a purely automated basis that has

## Personal information includes:

- Name/address
- Email addresses
- Phone numbers
- Credit/financial details
- Gender
- Opinions about a person
- Identification numbers e.g. passport/drivers licence
- Date of Birth
- ISP address

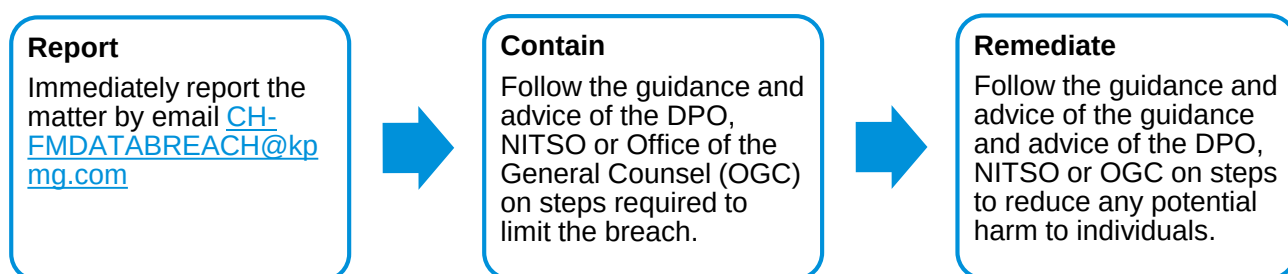
## Sensitive information includes:

- Race or ethnic origin
  - Political opinions
  - Membership of a political association, professional or trade association, or union
  - Religious or philosophical beliefs or associations
  - Sexual orientation or practices
  - Criminal record
  - Health information
  - Genetics
  - Biometric information
- 
- a legal or significant impact on an individual, the individual has to be given the opportunity to discuss the output of such processing before making those decisions.
  - Information Transfer and Compliance: Personal data can only be transferred if it is adequately protected.
  - Data Minimization: Personal data can only be retained as long as it serves the purpose(s) for which it was initially collected or subsequently authorized except to the extent permitted by law.

# Privacy, continued

## Data Breaches

- A data breach is an unauthorised access to or disclosure of, personal information, or loss of personal information
- A data breach can be malicious (cyber crime) or as simple as an accidental misdirected email
- KPMG is obliged to comply with the Federal Act on Data Protection (FADP) incl. notifiable Data Breach Scheme – so it is imperative that all staff follow the data breach notification protocol (below)
- If you become aware of or suspect a data breach has/will occur, you must report it immediately to the KPMG Data Protection Officer (DPO) and the Information Security Officer (NITSO) by email [CH-FMDATABREACH@kpmg.com](mailto:CH-FMDATABREACH@kpmg.com)



## Data Security

- The security of KPMG data is overseen by the NITSO and ITS
- It's important that everyone who interacts with KPMG data adheres to the relevant policies and protocols

## Governance of Privacy at KPMG

- Internal privacy matters are overseen and advised on by the DPO and OGC
- The DPO and Staff from OGC can help with regulatory advice, Privacy Impact Assessments for new projects and training

# Privacy, continued

In May 2018, the *General Data Protection Regulation (or the GDPR)* replaced all existing rules on data protection in EU member countries. The GDPR applies stringent, uniform privacy laws across the European Union “EU”. It focuses extensively on ensuring “data subjects” (individuals in Europe) know, understand and agree to exactly what their data is being used for. It strengthens their rights. It creates roles for organisations to protect data.

The GDPR may apply to KPMG in Switzerland when we provide services to people in the EU or monitor the activity of people in the EU. We may also need to meet EU Privacy requirements when collecting personal information from people in the EU via other KPMG firms or from our clients in Switzerland who have operations in the EU. Breaches of the GDPR carry heavy penalties.

KPMG as a global network has made a regulatory application for Binding Corporate Rules in 2019. This will mean that KPMG will enforce internally how we manage GDPR compliance, and will require consideration of what role we take in using data.

## What are the Binding Corporate Rules (BCRs)?

- BCRs apply between all members of a corporate group or affiliation allow all members of that group to transfer Personal Information across borders in compliance with data privacy law
- BCRs are a form of stringent inter-firm policies, practices, processes and guidelines which must be followed
- BCRs are officially recognised under GDPR and include “processor-to-processor” transfers of Personal Information, which will occur more frequently as our business moves toward asset-based business models.

## What will BCRs mean for the Firm?

- Binding Corporate Rules should make it easier to contract with our clients as they are widely understood and recognized as good practice in the marketplace.
- An external client facing BCR Privacy Notice will be posted to the [kpmg.com](https://www.kpmg.com) website and linked from the BCR language in engagement terms. This notice will explain the scope and coverage of our BCRs and how clients or others can exercise their rights under the BCRs or make a complaint.

## What is a Data Controller?

The Data Controller is an organisation ultimately responsible for compliance with Data Privacy legislation; however, Data Processors also have responsibilities.

The Data Controller determines the purpose and means under which the Personal Information is processed.

## What is a Data Processor?

The Data Processor is an organisation that processes the data on behalf of the Data Controller. The Data Processor must act on the Data Controller’s instructions, keep the data secure and not do anything that would put the Data Controller in breach of GDPR. Processing can involve merely accessing personal information.

**For questions and further information please contact the Data Protection Officer ([ch-fmdataprotectionofficer@kpmg.com](mailto:ch-fmdataprotectionofficer@kpmg.com))**

# Whistleblowing internally at KPMG

## Raising your Hand

You're required to report potential or suspected violations of KPMG policy or applicable laws, regulations or professional standards. This includes situations when you know or suspect that colleagues, clients or parties associated with clients, or suppliers, subcontractors or associated third parties are engaged – or may be about to engage – in illegal or unethical activity. At KPMG, you can raise issues without fear of retaliation knowing that we'll take appropriate action and there is zero tolerance for any form of retaliation.

KPMG offers many channels of communication to seek guidance and raise concerns. You should never feel you're alone when faced with an ethical dilemma.

Resources closest to the situation (e.g. an engagement partner) may be in the best position to resolve an issue. Depending on the issue, you may want to consider other channels, such as risk management. Always choose the channel you feel most comfortable with. The important thing is that you raise your hand.

## Why it matters:

By displaying your integrity, you can help restore public confidence in our firm and the industry.

- The 'outside' world looks at KPMG as being 'one firm' and any time the KPMG name appears in the media – good or bad – it reflects on you and everyone else at KPMG.
- Improper conduct damages our reputation, morale and culture which reduces our ability to attract and retain the best people.

## Do not tolerate wrong doing. Speak up.

Failure to report a suspicion can be seen as a sign that you have supported inappropriate behaviour.

Exercise common sense and scepticism.

# Whistleblowing internally at KPMG, continued

## How to report

Although no-one wants to be in a situation that requires it, KPMG fully respects that sometimes people don't feel comfortable to raise concerns directly. Please follow one of the following channels available to you:

### 1. KPMG International Hotline

KPMG Whistle-blowing Hotline\* is operated by external provider Clear View Connects. Notifications can be made, on an anonymous basis if desired, using the website or hotline (0) 00800 5555 5522. Please note that toll-free number above may not work from all locations, mobile phones or pay phones. If you call does not go through, please alternatively dial the US collect number: + 1 647 438 6817 (standard rates may apply). All concerns raised through this hotline will be investigated either directly by or under the supervision of our Ombudsman. If you need more information on KPMG's Hotline or to report concerns related to possible illegal, unethical or improper conduct through the Hotline, please visit <https://home.kpmg.com/xx/en/home/misc/international-hotline.html>

### 2. Swiss Whistle-blowing Hotline

The Firm has established a confidential web-based reporting system ("whistle-blowing hotline") for the reporting of matters relating to accounting, internal accounting controls, auditing, banking crime, financial crime and bribery as well as concerns relating to professional and other obligations (including activities by clients or suppliers that affect KPMG). To access the system please go to [ClearView Connects](#).

Since the system is international, any data entered into it will be accessible and stored outside of Switzerland. Given the strict data protection and secrecy legislation in Switzerland / Liechtenstein, care needs to be taken when entering information into the system and certain guidelines must be adhered to:

- No client name or identifying details should be entered into the system.
- No names or identifying details of individuals, including KPMG personnel, should be entered into the system.

The report will be forwarded to the Firm's Ombudsman: Dr. Stefan H. Schalch ([stefan.schalch@legis-law.ch](mailto:stefan.schalch@legis-law.ch)), Legis Rechtsanwälte AG, Forchstrasse 2 / Kreuzplatz, Postfach 1467, 8032 Zurich

Anyone that reports breaches or suspected breaches of KPMG policy in good faith will not suffer any adverse impact, regardless of whether or not the concern is ultimately substantiated. All KPMG firms and personnel are prohibited from retaliating against individuals who have the courage to speak up in good faith.

# Acceptable Use of Assets

## 1. Introduction

In this document, KPMG Switzerland describes its Acceptable Use Policy that applies to contractors engaged by KPMG when accessing or using KPMG Confidential Information, and/or KPMG Information Technology (IT) Resources. Terms used in this document are defined in the Appendix.

KPMG IT Resources are made available for use by individuals working with KPMG. All those authorised to access KPMG IT Resources must accept responsibility for your actions regarding its use, in accordance with the requirements outlined in this and other KPMG policies. You are required to comply with these policies.

Any exceptions to this AUP must be approved by the National IT Security Officer (NITSO) of KPMG Switzerland and/or Risk Management Partner (RMP). Individuals can submit a policy exception request via the National IT Service Desk.

This Acceptable Use Policy (AUP) sets out the minimum standards for the acceptable and appropriate use of KPMG's information and IT assets by individuals working with KPMG. It also sets out Firm-wide security policy on personal physical security matters. The AUP should be read in conjunction with the Global Quality and Risk Management Manual which is available via the KPMG Intranet portal. For guidance on the Global Quality and Risk Management Manual please reach out to the individual you are reporting to in KPMG.

## 2. Guiding Principles

KPMG regards its IT Resources as valuable business assets. Inappropriate conduct in the use or dissemination of KPMG Confidential Information may expose KPMG and its clients to risk. Therefore, in using KPMG IT assets, you must comply with applicable laws, regulations and related KPMG policies. You should remain mindful of your professional responsibilities and obligations communicated by KPMG.

**For help, guidance or clarification on this policy, please contact Information Security Office via email at [CH-FMSECURITY@kpmg.com](mailto:CH-FMSECURITY@kpmg.com)**

### The use of KPMG IT Resources is governed by the following guiding principles:

- Users of KPMG IT Resources must comply with applicable laws, regulations, professional standards and all related KPMG policies and manuals
- You must not do anything to compromise KPMG's brand, reputation or its relationships with its clients, or embarrass KPMG or its clients.
- When accessing the Internet using KPMG IT Resources you must not access, download or disseminate any illegal or offensive materials
- You must, in accordance with all relevant policies, guidance and established practices, take all reasonable steps to protect KPMG IT Resources and all information of KPMG and its clients that are in your possession or under your control against theft/loss, misuse, and unauthorized access, disclosure, modification, duplication, damage, and destruction
- You must not make representations or express opinions claiming to be those of KPMG or others, without the appropriate authority
- You must not infringe copyright, trademark or other intellectual property laws
- Confidential Information must be protected against unauthorized or inadvertent disclosure. Confidential or Personal Information must not be shared with anyone who does not have a business need to know the information. This applies to information regardless of whether it is in written, printed or electronic form
- You must comply with KPMG's Policy on Document Classification and all associated requirements. For guidance on information classification please reach out to the individual you are reporting to in KPMG
- In your dealings with others in KPMG, its clients or authorized third parties, you are prohibited from impersonating any other person, either in person or by using any technology or electronic means
- Breaches to this policy may violate laws and regulations. Where there are breaches of this policy, KPMG reserves the right to investigate where appropriate and to take disciplinary action up to and including dismissal

# Acceptable Use of Assets

## 3. Ownership of Information and IT Resources

- KPMG's IT Resources are provided to you for business purposes. Unless explicitly indicated to the contrary (and appropriately documented e.g. in a contract), all such IT Resources remain the property of KPMG. As such, KPMG reserves the right to monitor and review the use of any of its IT Resources. You must recognise that KPMG may exercise this right at any time without prior notice and on an ongoing basis
- Upon the termination of a contract, all KPMG IT Resources in the possession of or under the control of the affected individual must be promptly returned to KPMG

## 4. Protecting KPMG Intellectual Property

**The Intellectual Property of KPMG is a valuable asset and should be protected accordingly.**

- Any Intellectual Property created or contributed to by you during your employment is the property of KPMG
- KPMG Intellectual Property may not be published, distributed, duplicated or otherwise disseminated in electronic or physical form, except as expressly authorised by appropriate KPMG management
- You must not remove trademarks (®, TM), copyright notices, user agreements, disclaimers or other notices applied or displayed to protect KPMG Intellectual Property from documents, files, software or other products containing KPMG Intellectual Property when they are printed, provided, published, distributed, duplicated or otherwise disseminated

## 5. Business vs. Personal Use

KPMG's IT Resources and Information Assets are provided to you and authorised third parties for business purposes.

### Personal Use where permitted

- Personal use of KPMG IT resources is permitted, provided it is reasonable and does not breach any KPMG global or local KPMG policies. In addition any personal use must in KPMG's view not:

- Consume excessive resources (this includes the long term storage of personal files on KPMG devices/servers);
- Interfere with individual productivity;
- Impede any KPMG business activity; or
- Generate any issues which in KPMG's view may compromise the reputation of KPMG
- Special care should be taken in the personal use of social networking sites and in blogging to ensure that any personal opinions expressed are not attributed to KPMG and that the guiding principles set out in this policy are not compromised. Under no circumstances may client or KPMG confidential matters be discussed using unapproved social media. The personal use of social network and other networking sites is governed by the KPMG Switzerland Social Media Policy which is available via the KPMG Intranet portal. For guidance on Social Media Policy please reach out to the individual you are reporting to in KPMG
- When registering, subscribing or posting online, you must not use your KPMG e-mail address or other KPMG details unless such use is for genuine business or professional purposes
- You must not use your KPMG network password for other systems
- You may not load software for personal use, unless this is specifically permitted by the firm

### Use of Personal or Other Third Party Equipment and Services

- Confidential Information must not be transferred to or stored on any personally owned or other Third Party IT Equipment or service (whether copied, transmitted or by other means) without approval. This includes mobile devices such as mobile phones, smart phones, and portable storage media
- No non-KPMG devices should be connected to the KPMG network

# Acceptable Use of Assets

- Non-KPMG devices may be connected to the guest KPMG network
- When using any external storage device, you should initiate a manual scan if an automated scan does not start by itself when inserted into a KPMG device
- You must not set up, activate or use any service or device intended secretly to record or transmit details of KPMG or client confidential meetings or discussions to any other person not directly involved in the meeting. Unauthorised surveillance of any individual is prohibited
- A recording made for the purpose of preparing minutes or for replay at a later date to authorised individuals is permitted provided that the making of any such recording is disclosed to all participants at the start of the meeting or discussion

## 6. Protecting KPMG Assets and Media

- Remote access to KPMG Information Assets is only permitted through KPMG-approved secure methods
- The removal of any KPMG IT Equipment or KPMG Information Assets not assigned to you individually from KPMG premises is not permitted without prior approval. The National IT Service Desk must be notified, and the approval provided must be included in the notification
- You are required to maintain a “clean desk”. This means that when a user leaves his or her desk for an extended period (a half day or longer and especially overnight), all documents, files, media and portable computing equipment must be cleared and secured in a locker if provided by KPMG
- If using a KPMG provided laptop, you must ensure that your devices are connected to the internet by VPN or KPMG network on a regular basis to ensure that anti-virus definitions, security patches and software updates are implemented in a timely manner

## Securing KPMG IT Equipment When working remotely and Travelling

Do not leave any KPMG IT Equipment which stores KPMG Information Assets unattended. Under no circumstances should KPMG IT Equipment be left overnight in a vehicle

- When travelling, always be aware of the whereabouts of your assigned KPMG IT Equipment and Information Assets
- A KPMG managed laptop or other laptop storing KPMG Information Assets must never be checked-in as baggage unless this is mandated by airport security officials. If placing the laptop in any overhead compartment, it is always advisable to place it where it is within easy reach and view
- When working remotely, carefully consider the physical working environment and ensure that confidentiality is maintained and information kept secure

## Protecting KPMG Premises

- If working on the KPMG premises, you should not allow unidentified individuals to tailgate into secured office spaces
- You should always display your identification badges issued by KPMG or clients
- Securely dispose of all confidential paper document, e.g., reports, envelopes, fax paper in the secured document destruction bins which are available on every floor of the KPMG premises
- Return all electronic media such as USB drives, external hard drives, video tape, microfilm, CD / DVD, computer disk or any electromagnetic media to the IT service desk for secure destruction

## 7. Software Use

Only KPMG approved software may be used for KPMG business purposes

Software that are intended solely for personal use where possible is discouraged on devices fully managed by KPMG. You must not install or use any software explicitly prohibited unless an exception has been pre- approved only by the NITSO of the Information Security Office.

# Acceptable Use of Assets

Any software included in the list of prohibited software, or subsequently added to this list, must be promptly removed from KPMG devices. The installation or use of prohibited software on a KPMG device, or failure to remove prohibited software from a KPMG device promptly, may result in disciplinary action

- You must not access, download, install or execute any software tool that is designed to monitor or sniff network traffic, or perform any form of network analysis without the explicit pre-approval of the NITSO of Information Security Office of KPMG Switzerland
- You must not change or disable any configuration and settings including but not limited to security related software that is part of the standard configuration provided by ITS, e.g. anti-virus software
- The deliberate introduction of viruses or malicious code into KPMG systems, software or devices is prohibited.

To avoid being infected by malware, you should exercise caution when:

- Downloading content from the Internet;
- Receiving data from others through media or e-mail.

You should seek guidance from the IT Service Desk to resolve any questions regarding the use of software on KPMG computers.

## 8. Access to KPMG Information

### Passwords and Other Credentials

regarding the use of software on Individuals access all KPMG IT Resources using unique personal credentials, issued to them by KPMG. These credentials must be protected.

- You must make every effort to protect login/sign on credentials and the associated passwords, PINs, tokens, and other access devices from disclosure to others and from loss.
- You are personally accountable for all system activity that occurs using your assigned credentials and it is therefore imperative that these be properly protected and that they are never shared with others.

- Remote access to KPMG IT Resources is only permitted through KPMG-approved secure methods.
- A password-protected screensaver should be activated whenever a KPMG computer is left unattended. For the current Desktop based on Windows, this is done by simultaneously pressing Ctrl+ Alt+ Del keys and then clicking the Lock Workstation button (or by simultaneously pressing the Windows and the "L" key).
- When selecting passwords, you should create a complex password (or passphrase) that is both difficult to guess and yet easy to remember (so that it need not be written down anywhere). Passwords must avoid personal information (names, dates, sports teams, etc.), simple dictionary words or predictable keyboard sequences.
- Passwords should be a minimum of eight (8) characters and contain at least three (3) of the following four (4) classes; Upper case letters (e.g., A, B, C ...Z) Lower case letters (e.g., a, b, c ...z) Numbers (e.g., 1, 2 ...9) Special characters (e.g., ?, !, %, \$, #, etc.).
- Admin account passwords should a minimum of 15 characters.
- You must never use the same password for both home and work.
- Passwords must be changed every 90 days as a minimum and every 60 days for admin accounts.

## 9. Use of Electronic Communication and Internet

### Use of the Internet

Individuals accessing the Internet using KPMG IT Resources must comply with applicable laws and regulations and ensure that they do not compromise the reputation of KPMG or its clients, either with reference to the websites accessed or the information downloaded or posted. Inappropriate use of the Internet includes, but is not limited to, deliberately accessing for the purpose of viewing and/or interacting with:

- Pornographic websites;
- Gambling, on-line casinos and similar websites;

# Acceptable Use of Assets

- Websites containing details of or encouraging illegal activities;
- Other websites that may damage KPMG's reputation; and
- Other categories of websites that may present a risk to KPMG or its systems.

You must not use Internet based unapproved instant messaging tools, social media, chat-sites, or blogs (or similar functions provided within other software tools) for KPMG, client or engagement related communications,

## E-Mail and other Electronic Communications

KPMG provides IT Resources for reliable and secure electronic communication in line with legal and business requirements. Only KPMG-approved communication methods may be used for business-related communication.

- KPMG cannot guarantee that communication through the use of KPMG's electronic communication tools will be private.
- You must not use internet based instant messaging tools, chat-sites, or blogs (or similar functions provided within other software tools) for KPMG, client or engagement related communications, unless expressly approved by KPMG.
- The automatic forwarding of any electronic communication to a non-KPMG destination is prohibited. Forwarding KPMG or client information to a personal email account, for working offline on home based managed devices, is prohibited.
- Third parties must only use KPMG currently approved electronic communication tools when using KPMG or approved non-KPMG IT assets. Third parties must be provided with the current KPMG approved electronic communication tools by the KPMG management that is sponsoring your activity.
- No KPMG information may be transmitted to parties not authorized or entitled to receive such information. Where an external third party is required to disseminate KPMG information, they should obtain appropriate

KPMG management approval.

- The KPMG approved disclaimer and confidentiality notice that is automatically included in all outgoing KPMG e-mails should never be deleted.
- The sender must be clearly identified and not misrepresented in electronic communication sent through the KPMG IT network. When such a communication is sent on behalf of another, the originator of the communication must be clearly indicated, e.g., "This message is sent on behalf of [name]."
- When conducting any online meeting that uses screen or other application sharing capabilities, you must be careful to ensure that only the intended participants are present and are sharing the intended information.
- When sending emails both internally and externally, please ensure you do not leave the subject line blank.
- If KPMG information is known to have been sent to an unintended recipient, this must immediately be reported by mail at *CH-FMDATABREACH@kpmg.com*.

## Appropriate Use of the KPMG Intranet or Portal sites

Individuals accessing KPMG's private intranet, portal and collaboration services must comply with the KPMG intranet usage policy which is available via the KPMG Intranet Portal. *For guidance on the KPMG Intranet Usage Policy please reach out to the individual you are reporting to in KPMG.*

## Appropriate use of External Social media

Any discussions relating to the use of external social media must be in line with KPMG policies, and the use of social networks and other networking sites is governed by the KPMG Australia Social Media Policy which is available via the KPMG Intranet Portal. *For guidance on the Social Media Policy please reach out to the individual you are reporting to in KPMG.*

Information posted to an online/internet network and the internet in general is publicly available, and can be disclosed in any litigation.

# Acceptable Use of Assets

You will be held personally responsible for any information posted. Any discussions using a KPMG approved internal social collaboration tool, must be in line with KPMG policy and guidance.

In relation to the use of personal social media:

- Information posted to social media is publicly available, and therefore may be used as evidence in any claim, dispute or proceeding. Individuals will be personally liable for any information posted which is deemed to be defamatory, a form of harassment, or in contravention of other civil, professional or criminal laws.
- When subscribing to or posting information to social media, you must not use your KPMG e-mail address or other KPMG details, unless such use is required for genuine and approved business or professional purposes.
- Any information that may cause damage to KPMG's reputation or may be considered confidential or commercially sensitive, including information (business or personal) about clients, colleagues, contractors and other third parties associated with KPMG, must not under any circumstances be disclosed externally.
- Any references, recommendations or endorsements that are given through social media services must be in line with KPMG Australia Social Media policy owned by the National Risk Management Team, which is available via the KPMG Intranet Portal. For guidance on the Social Media Policy Manual please reach out to the individual you are reporting to in KPMG.
- The KPMG logo or other identifiable KPMG branding must not be posted to a website without the prior approval of KPMG Marketing division or National Risk Management.

## Appropriate use of External and Internal Video Conferencing

KPMG approved collaboration, communication tools such as (for example, WebEx, Skype for Business and standard video) should only be used in a manner that is consistent with KPMG's policy on confidentiality including the Global Quality and Risk Management Manual and Global Code of Conduct, which is available via the KPMG Intranet Portal.

For guidance on the Global Quality and Risk Management Manual please reach out to the individual you are reporting to in KPMG.

To maintain the integrity and availability of KPMG Information Assets both for day-to-day operational purposes and for longer term conferencing) should only be used in a manner

- When engaging in both internal and external conferences please ensure that classified KPMG documentation is only shared in line with the Data Classification Security Standard and Data Classification User Guidelines which is available via the KPMG Intranet Portal. For guidance on KPMG Data Classification please reach out to the individual you are reporting to in KPMG.
- All conversations held with external customers, partners and clients may be recorded. Each participant needs to ensure that they fully understand and follow the Data Classification Security Standard and Data Classification User Guidelines which is available via the KPMG Intranet Portal. For guidance on the Data classification please reach out to the individual you are reporting to in KPMG.

## 10. Connecting to Client Networks

In the course of providing client services, it may be necessary for you to connect your KPMG issued computer to a Client's Network (guest Wi-Fi or corporate wired network).

Please refer to Connecting to Client -Quick Reference Guide for more detail and FAQ which is available via the KPMG Intranet Portal. *For guidance on the Client – Quick Reference Guide please reach out to the individual you are reporting to in KPMG.*

## Controls for Connecting to Client Networks

KPMG managed devices may be connected to client IT networks only with:

- Permission of the client in writing (e.g., in the engagement contract)
- Authorization of the engagement or lead partner in writing, as appropriate

# Acceptable Use of Assets

- Notification to the KPMG member firm's ITS organization
- Disabling of file-sharing functionality
- Up-to-date anti-virus software and definitions, an operational KPMG-approved personal firewall, and all appropriate security patches installed on the KPMG managed device.

KPMG managed computers connected to Client Networks may at the same time connect to KPMG IT network only via authorised connections (e.g., KPMG Virtual Private Network or "VPN"). For any other type of connection to KPMG network while connected to a client IT network, the approval of the NITSO or RMP is required.

## Controls for Connecting to the KPMG Network outside of KPMG.

Users are permitted to use guest Wi-Fi networks provided they follow the standards outlined above. Guest Networks may include Wi-Fi networks such as:

- Home networks
- Hotel networks
- Airport guest wireless
- Client Network (provided the client has provided approval)
- Guest public wireless

It is the responsibility of the user to ensure they connect to the KPMG network on a KPMG approved device using the VPN.

## Authorized activity using Client Networks

You may only access a Client Network for the purposes explicitly agreed to with the client.

- Access to Client Networks may only take place using individually assigned credentials, issued by the client. In no circumstances should credentials be shared by individuals unless directed to do so by the client.
- No client materials may be accessed, downloaded, transmitted or stored other than as explicitly agreed to with the client.

- KPMG network should not be connected/bridged to the client network in a manner that circumvents KPMG network security controls.

## 11. Backup, Storage and Retention

The handling of electronic files related to engagements is governed by the **Working Papers Policy** which is available via the KPMG Intranet Portal . For guidance on the policy please reach out to the individual you are reporting to in KPMG. For archiving/retention, the following additional controls should be applied:

### Backup and Storage

- At the end of a client engagement, electronic files related to that engagement must be transferred off KPMG workstations/laptops onto a central KPMG data server or into the KPMG document management system for storage in accordance with the firm practices.
- KPMG or engagement-related information produced during the course of providing professional services to a client must not be stored or backed up on a client, personal or other non-KPMG computer, portable storage device, mobile device (including smart phones) or server except as required in order to fulfil the terms of the engagement contract e.g., the short term back-up of eAudit files. Any KPMG Information Asset, including client information, stored on such devices must be encrypted.
- Removable media should not be used for long term retention of KPMG Information Assets. All encryption requirements for protecting KPMG Information Assets must be complied with.
- You must not backup any KPMG device (and the data stored on it) to any Cloud service without the express prior approval of the NITSO.

### Retention

- Retention policies, guidance and processes specified in KPMG policy/manuals apply equally to any information maintained in either physical or electronic form.
- All electronic communication (including printed copies) must be retained in accordance with the Working Paper Policy which is available via the

# Acceptable Use of Assets

KPMG Intranet Portal. For guidance on the KPMG Working Paper Policy please reach out to the individual you are reporting to in KPMG. Electronic communication is treated as permanent, written business communication subject to the same policies and guidance as any other written business communication and in accordance with any contractual agreement with KPMG that is in place. Voice messages should be transcribed if retention is considered necessary.

## 12. Incident and Data Loss Reporting

You have a duty to protect all Information Assets that come into your possession during your association with KPMG and while under your control. This responsibility applies equally whether in KPMG offices, in transit or working at other locations (e.g. at a client site or at home).

It is imperative that Information Security Incidents be immediately identified and reported to the IT Service Desk. You must not attempt to resolve Information Security Incidents yourself, but rather seek assistance by contacting the IT Service Desk. If any individual becomes aware of a security weakness or vulnerability in any KPMG IT system, they must promptly report this to the IT Service Desk; they must not try to test or exploit any such weakness or vulnerability.

- Any loss of information, intellectual capital, software or physical assets (or client/third party information) including for example information on laptops, smart phones, USB devices and CDs, must be promptly reported in accordance with the procedures established by the firm.
- If you believe that your credentials may have been compromised or lost, they must promptly report this to IT Service Desk in order for the appropriate actions to be taken as soon as possible.
- In the event that a token or other access device is lost, the incident must immediately be reported to the IT Service Desk following the process established by the member firm.

- Any Actual or suspected virus-related problem must immediately be reported to the IT Service Desk. You must not attempt to address virus-related problem yourself, but rather seek assistance from the IT Service desk.
- You must immediately report any information security incident to the IT Service Desk.
- If an individual becomes aware of a security weakness or vulnerability in any KPMG IT system, they must promptly report this through the locally established channels; they must not try to test or exploit any such weakness or vulnerability.
- You must promptly notify IT Service Desk if any mobile device used for KPMG business purposes is lost; please note that in these circumstances, and where technically feasible, lost devices will be remotely wiped which could involve the loss of personal data on the device.

## 13. Monitoring and Enforcement

**KPMG reserves the right to monitor all use of its IT Resources.**

- Subject to applicable laws or regulations, KPMG may examine:
  - Email sent via KPMG network
  - Internet Services
  - Files written to USB
  - Print logs
- KPMG reserves the right to monitor and remove any software, files or information stored on any KPMG computer, portable storage device or server as considered appropriate to ensure ongoing compliance with KPMG policies. This includes personal or other Third Party equipment and services as per the Use of Personal or Other Third Party Equipment and Services section in this document.
- KPMG reserves the right to discipline any individual for breaches of laws, regulations or policy up to and including termination of contract. Comparable breaches by authorised third parties may be considered cause for the termination of the contractual arrangements with KPMG.

# Acceptable Use of Assets

- KPMG reserves the right to monitor and review the use of KPMG managed IT and information assets. All individuals must recognize that KPMG may exercise this right at any time without prior notice, subject to any applicable law or regulations.
- KPMG reserves the right to rescind access, without notice, to KPMG networks and use KPMG IT assets and resources, for breaches of laws regulations, or policy.
- KPMG-issued computers may be used by authorised third parties and contractors engaged by KPMG only in accordance with the instructions provided by KPMG Management.
- External third parties must execute an appropriate license agreement prior to gaining access to or receiving copies of firm-developed (KPMG proprietary) software or associated electronic content or user documentation, with the exception of marketing-related materials.

## Optical Surveillance

- Optical Surveillance means the use of cameras and closed circuit television (CCTV) for surveillance in KPMG's office foyers, internal lift lobby access points and internal security areas (e.g. IT hardware store rooms).
- KPMG also conducts Optical Surveillance to protect the ongoing security of all KPMG workplaces. Optical Surveillance security footage may capture KPMG people from time to time as well as clients, contractors and other visitors/members of the public.
- Monitoring of Optical Surveillance security footage is a continuous (24 hours) and ongoing and is only accessed by KPMG people and building management employees with security responsibilities for the firm. Where footage reveals illegal activity on KPMG premises, footage will be provided to the relevant authorities.
- People who are suspected or known to be involved in inappropriate behaviour, breach of KPMG policy, illegal activity or where such people present an immediate threat to people or property, KPMG will access Optical Surveillance security footage to investigate such matters.
- External third parties and contractors engaged by KPMG must not install or use copies of KPMG licensed commercial software on third party IT equipment without proper authorisation from KPMG management.
- Third parties may access and use external content in accordance with the applicable license terms, copyrights, or other requirements agreed with or specified by the owner of such content. Furthermore, third parties must not copy, distribute, provide or otherwise disseminate external content to those not covered under the license.
- At the conclusion of third party services or contract, or upon request by KPMG Management, all KPMG IT Resources and Information Assets must be returned to KPMG.
- At the conclusion of third party services or contract, or upon request by KPMG Management, all KPMG Information must be removed from any IT Resources owned or controlled by anyone other than KPMG. This must be specified in the original contract that establishes the third party services.

## 14. Additional Emphasis for Third Parties

**The following requirements for third parties are specifically emphasised below:**

Access to KPMG IT Resources and KPMG Information by third parties and contractors engaged by KPMG is limited by the written authorisation provided by Partners and is limited to the duration of the engagement/project. Where client information is accessed, client permission is required.

## 15. Mobile Devices

The following supplementary clauses relate specifically to the use of mobile devices for KPMG business purposes.

- For contractors KPMG Switzerland supports a Bring Your Own Device (BYOD) program for only mobile devices (tablets or smart phones), you must comply with firm's policies and practices surrounding the registration and use of your mobile device for KPMG purposes. User should make separate provision to back up personal data on the device

# Acceptable Use of Assets

- Only applications from a trusted source may be installed.
- KPMG devices must be kept current by promptly accepting software updates in line with firm instructions.
- External third parties must execute an appropriate license agreement prior to gaining access to or receiving copies of firm-developed (KPMG proprietary) software or associated electronic content or user documentation, with the exception of marketing-related materials.
- External third parties and contractors engaged by KPMG must not install or use copies of KPMG-licensed commercial software on third party IT equipment without proper authorisation from KPMG management.
- Third parties may access and use external content in accordance with the applicable license terms, copyrights, or other requirements agreed with or specified by the owner of such content. Furthermore, third parties must not copy, distribute, provide or otherwise disseminate external content to those not covered under the license.
- At the conclusion of third party services or contract, or upon request by KPMG Management, all KPMG IT Resources and Information Assets must be returned to KPMG.
- At the conclusion of third party services or contract, or upon request by KPMG Management, all KPMG Information must be removed from any IT Resources owned or controlled by anyone other than KPMG. This must be specified in the original contract that establishes the third party services.

## 16. Monitoring: Optical Surveillance

- KPMG also conducts Optical Surveillance to protect the ongoing security of all KPMG workplaces. Optical Surveillance security footage may capture KPMG people from time to time as well as clients, contractors and other visitors/members of the public.
- Monitoring of Optical Surveillance security footage is a continuous (24 hours) and ongoing and is only accessed by KPMG people and building management employees with security responsibilities for the firm.
- Where footage reveals illegal activity on KPMG premises, footage will be provided to the relevant authorities.

People who are suspected or known to be involved in inappropriate behaviour, breach of KPMG policy, illegal activity or where such people present an immediate threat to people, KPMG will access Optical Surveillance security footage to investigate such matters.

## 17. Monitoring: E-mail and Services Internet

- KPMG actively monitors the use of technology as defined by the KPMG Acceptable Use Policy. Specifically this includes the monitoring of E-mail (both internal and external) and internet usage, to business services has been used in breach of the “Acceptable Use Policy”, further investigation of E-mail and internet logs and content (including hard drive records of such activity and storage) will be conducted.
- Monitoring of E-mail and Internet services is regular and ongoing and includes reporting on the following user attributes:
  - Volume of E-mail and internet use
  - Inappropriate E-mail content filtered automatically
  - Internet sites accessed
  - Information/other downloads from the internet.

# Acceptable Use of Assets

- KPMG uses specific software to automate the monitoring and reporting of the use of technology within the firm. However, KPMG will also conduct more thorough monitoring and investigation of these business tools where automated monitoring tools identifies real or potential breaches of the Acceptable Use Policy. Such investigation may include hard drive reviews or other business tool record management reviews. Appropriate use of E-mail or Internet services may constitute a violation of the Acceptable Use Policy, and in some cases:
- The Firm's EEO, sexual harassment and harassment and bullying policies
- Local, state and/or federal laws.

**Any exceptions to this Acceptable Use Policy must be approved by the NITSO and/or RMP of KPMG Switzerland. Individuals can submit a policy exception request via the IT Service Desk.**



# Appendices

- Appendix 1: Privacy Policy

# Appendix 1 – Privacy Policy

We are dedicated to protecting the confidentiality and privacy of information entrusted to us. We comply with applicable Data Protection Regulations including in particular the Swiss Federal Act on Data Protection (FADP). Please read this Privacy Policy to learn about your rights, what information we collect, how we use and protect it.

This website is operated by KPMG AG, a Swiss corporation and subsidiary of KPMG Holding AG, which is a member firm of the KPMG global organization of independent member firms affiliated with KPMG International Limited (“KPMG International”), a private English company limited by guarantee. KPMG International does not provide client services.

## 1. Who are we?

This Privacy Policy applies to KPMG Holding AG and its subsidiaries in Switzerland and Liechtenstein consisting of: KPMG AG, KPMG (Liechtenstein) AG, Ostschweizerische Treuhand-Gesellschaft AG, Fides Revision AG and KPMG Tax & Legal Services (together “KPMG”, “we” or “us”).

## 2. Who can you contact for privacy questions or concerns?

If you have questions or comments about this Privacy Policy or how we handle personal data, please direct your correspondence to:

KPMG AG  
Data Privacy Officer  
Räffelstrasse 28  
P.O. Box  
8036 Zurich  
Switzerland  
[Dpo@kpmg.ch](mailto:Dpo@kpmg.ch)

To report concerns you may have about our data handling practices you can contact the responsible data protection supervisory authority:

- Switzerland: [Federal Data Protection and Information Commissioner](#)
- Liechtenstein: [Datenschutzstelle in Liechtenstein](#)

## 3. How do we collect personal data?

- **Directly.** We obtain personal data directly from individuals in a variety of ways, including obtaining personal data from individuals who provide us their business card, complete our online forms, subscribe to our newsletters and preference centre, register for webinars, attend meetings or events we host, visit our offices or apply for open positions. We may also obtain personal data directly when, for example, establishing a business relationship, performing professional services through a contract, or through our hosted software applications.
- **Indirectly.** We obtain personal data indirectly about individuals from a variety of sources, including recruitment services and our clients. We may attach personal data to our customer relationship management records to better understand and serve our business clients, prospects, subscribers and individuals, satisfy a legal obligation, or pursue our legitimate interests.
  - *Public sources* – Personal data may be obtained from public registers (such as Commercial Registers), news articles, sanctions lists, and Internet searches.
  - *Social and professional networking sites* – If you register or login to our websites using social media (e.g., LinkedIn, Google, or Twitter) to authenticate your identity and connect your social media login information with us, we will collect information or content needed for the registration or login that you permitted your social media provider to share with us. That information may include your name and email address and depending on your privacy settings, additional details about you, so please review the privacy controls on the applicable service to set how much information you want shared with us.
  - *Business clients* – Our business clients may engage us to perform professional services which involves sharing personal data they control as part of that engagement. For example, we will review payroll data as part of an audit and we often need to use personal data to provide global mobility and

# Appendix 1 – Privacy Policy

- pension services. Our services may also include processing personal data under our clients' control on our hosted software applications, which may be governed by different privacy terms and policies.
- *Recruitment services* – We may obtain personal data about candidates from an employment agency, and other parties including former employers, and credit reference agencies.

## 4. What categories of personal data do we collect?

We may obtain the following categories of personal data about individuals through direct interactions with us, or from information provided through client engagements, from applicants, our suppliers and through other situations including those described in this Privacy Policy.

- **Personal data.** Here is a list of personal data we commonly collect to conduct our business activities.
  - Contact details (e.g., name, company name, job title, work and mobile telephone numbers, work and personal email and postal address)
  - Professional details (e.g., job and career history, educational background and professional memberships, published articles).
  - Family and beneficiary details for mobility, official approvals and permits, insurance and pension planning services (e.g., names and dates of birth).
  - Financial information (e.g., taxes, payroll, investment interests, pensions, assets, bank details, insolvency records).
  - Video monitoring systems at our sites may collect images of visitors. We automatically overwrite such video monitoring footage within 60 days.

- **Sensitive personal data.** When we do need to process sensitive personal data, it is with the consent of the individual unless it is obtained indirectly for legitimate purposes. Examples of sensitive personal data we may obtain include:
  - Personal identification documents that may reveal race or ethnic origin, religious beliefs or physical health, and possibly biometric data of private individuals, beneficial owners of corporate entities, or applicants.
  - Expense receipts submitted for individual tax or accounting advice that reveal affiliations with trade unions or political opinions.
  - Adverse information about potential or existing clients and applicants that may reveal criminal convictions or offences information.
  - Information provided to us by our clients in the course of a professional engagement.
  - Dietary restrictions when registering for events that reveal religious beliefs or physical health.
- **Children data.** Although, our sites and services are not intentionally designed for or directed at children, we may occasionally receive details about children e.g. as part of an engagement to provide professional services or children attending events we host with their parents or guardians.
- **Location-based data.** We may process geographical locations, e.g. when you are using our website to locate an office near you.

## 5. What lawful reasons do we have for processing personal data?

We may rely on the following lawful reasons when we collect and use personal data to operate our business and provide our products and services:

- **Contract** – We may process personal data in order to perform our contractual obligations.
- **Consent** – We may rely on your freely given consent at the time you provided your personal data to us.

# Appendix 1 – Privacy Policy

- **Legitimate interests** – We may rely on legitimate interests based on our evaluation that the processing is fair, reasonable and balanced. These include:
    - *Delivering services and products* – To deliver the services and products our clients have engaged us to provide.
    - *Marketing* – To deliver timely industry insights and professional knowledge, offerings and invitations we believe are welcomed by our business clients, prospects, subscribers and other individuals.
    - *Recruitment* – To seek for qualified candidates.
  - **Legal obligations and public interest** – We may process personal data in order to meet regulatory and public interest obligations or mandates.
- Authenticating registered users to certain areas of our sites.
  - Processing online requests, including responding to communications from individuals or requests for proposals and quotations.
  - Contacting journalists regarding market insights, corporate news, invitations to press conference, highlighting messages that may be of interest on specific industry topics.
  - Travel arrangement assistance.
  - Complying with legal and regulatory obligations relating to sanctions, embargo assessment, countering money laundering, terrorist financing, fraud and other forms of financial crime.
  - Preventing fraud or criminal activity, safeguarding our IT systems and handling of claims.
  - Employment of personnel and work processes.
  - Seeking for qualified candidates.

## 6. Why do we need personal data?

We aspire to be transparent when we collect and use personal data and tell you why we need it, which typically includes:

- Providing professional advice and delivering reports and services related to our tax, advisory, audit and assurance, pension scheme administration, legal, restructuring, mergers and acquisitions and other professional services and products.
- Promoting our professional services, products and capabilities to existing and prospective business clients.
- Sending invitations and providing access to guests attending our events and webinars or our sponsored events.
- Personalising online landing pages and communications we think would be of interest based on interactions with us and KPMG member firms.
- Administering, maintaining, developing and ensuring the security and functionality of our information systems, applications and websites.

In some situations the provision of personal data is required to provide the services in such cases this is indicated on the Website accordingly or pointed out in the disclaimers or contractual agreements.

Furthermore, we may be required to collect certain personal data by law. If you fail to provide such data, we may not be able to provide the services, or we may have to cancel a product or service you have with us.

## 7. Do we share personal data with third parties?

We may share personal data with trusted third parties to help us deliver efficient and quality services and products. These recipients are contractually bound to safeguard the data we entrust to them. We may engage with several or all of the following categories of recipients:

- Member firms of the KPMG network, where necessary for administrative purposes (e.g. hosting and supporting IT applications, performing client conflict checks, HR support functions) and to provide professional services to our clients (e.g., when providing services involving advice from KPMG member firms in different territories).

# Appendix 1 – Privacy Policy

- Parties that support us as we provide our services and products (e.g. providers of telecommunication systems, mailroom support, IT system support, archiving services, document production services and cloud-based software services, scanning services).
- Our professional advisers, including lawyers, auditors and insurers.
- A potential buyer, transferee, merger partner or seller and their advisers in connection with an actual or potential transfer or merger/acquisition of part or all of our business or assets, or any associated rights or interests.
- Payment services providers.
- Marketing services providers.
- Law enforcement or other government and regulatory agencies (e.g. FAOA, FINMA) or to other third parties as required by, and in accordance with, applicable law or regulation.
- Recruitment services providers.

## 8. Do we transfer your personal data outside Switzerland or Liechtenstein?

We store personal data on servers located in Switzerland, and in some cases in Liechtenstein. We may transfer personal data to KPMG International, KPMG member firms, and reputable third party organisations situated inside or outside Switzerland and Liechtenstein when we have a business reason to engage these organisations. Each organisation is required to safeguard personal data in accordance with our contractual obligations and applicable data protection legislation. Such safeguards may include transfer to countries that have been deemed to provide an adequate level of protection according to lists of countries published by the Federal Data Protection and Information Commissioner; applying standard data protection model clauses, binding corporate rules or other standard contractual obligations which provide for appropriate protection of data.

## 9. Do we use cookies? Do we automatically collect personal information?

In some instances, KPMG AG and its service providers use cookies, web beacons and other technologies to automatically collect certain types of information when you visit us online, as well as through emails that we may exchange. The collection of this information allows us to customize your online experience, improve the performance, usability and effectiveness of KPMG's online presence, and to measure the effectiveness of our marketing activities. Where cookies are used, a statement will be sent to your browser explaining the use of cookies. To learn more, please refer to our Cookie Policy.

## 10. What are your data protection rights?

If KPMG processes personal information about you, you have the rights listed below. Before responding to your request, we may ask for proof of identity. This helps us to ensure that personal data is not disclosed to any person who has no right to receive it. We may also ask you for sufficient information about your interactions with us so that we can locate your personal information.

- **Access** – You can ask us to verify whether we are processing personal data about you, and if so, to provide more specific information.
- **Correction** – You can ask us to correct our records if you believe they contain incorrect or incomplete information about you.
- **Erasure** – You can ask us to erase (delete) your personal data after you withdraw your consent to processing or when we no longer need it for the purpose it was originally collected and no retention requirements exist.
- **Processing restrictions** – You can ask us to temporarily restrict our processing of your personal data if you contest the accuracy of your personal data, prefer to restrict its use rather than having us erase it.
- **Data portability** – In some circumstances, where you have provided personal data to us, you can ask us to transmit that personal data in electronic form if technically feasible.

# Appendix 1 – Privacy Policy

- **Automated Individual Decision-making** – You can ask us to review any decisions made about you which we made solely based on automated processing, including profiling, that produced legal effects concerning you or which significantly affected you.
- **Right to Object to Marketing including Profiling** – You can object to our use of your personal data for marketing purposes, including profiling. We may need to keep some minimal information to comply with your request to cease marketing to you.
- **Right to Object to Active Sourcing** – You can object to our use of your personal data for active sourcing purposes. We may need to keep some minimal information to comply with your request to cease recruiting activities
- **Right to Withdraw Consent** – You can withdraw your consent that you have previously given to one or more specified purposes of processing your personal data. This will not affect the lawfulness of any processing carried out before you withdraw your consent. It may mean we are not able to provide certain products or services to you and we will advise you if this is the case.

To submit a data request please direct your correspondence to:

KPMG AG  
Data Privacy Office  
Räffelstrasse 28  
P.O. Box  
8036 Zurich  
Switzerland  
[DPO@kpmg.ch](mailto:DPO@kpmg.ch)

We aim to respond within 30 days from the date we receive privacy-related communications. No fee is required to make a request unless your request is clearly unfounded or excessive. Depending on the circumstances, we may be unable to comply with your request based on other lawful grounds.

## 11. What about personal data security?

We have put appropriate technical and organisational security policies and procedures in place to protect personal data (including sensitive personal data) from loss, misuse, alteration or destruction. KPMG AG's protection of client data in relation to the provision of professional services, including people, processes and technologies for the engineering, deployment operations, and support of the data processing infrastructure is certified according to ISO 27001:2013. We limit access to personal data in general. Those individuals who have access to the data are required to maintain the confidentiality of such information. We may apply pseudonymization, de-identification and anonymization techniques in efforts to further protect personal data.

If you have access to parts of our websites or use our services, you remain responsible for keeping your user ID and password confidential. Please be aware that the transmission of data via the Internet is not completely secure. Whilst we do our best to try to protect the security of your personal data, we cannot ensure or guarantee the security of your data transmitted to our site; any transmission is at your own risk.

## 12. How long do we retain personal data?

We retain personal data to provide our services, make offerings, stay in contact with you and to comply with applicable laws, regulations and professional obligations that we are subject to. We retain personal data for so long as the personal data is needed for the purposes for which it was collected or in line with legal and regulatory requirements or contractual arrangements. We will dispose of personal data when we no longer need it.

# Appendix 1 – Privacy Policy

## **13. Do we link to other websites?**

Our websites will typically contain links to other sites, including sites maintained by other KPMG member firms that are not governed by this Privacy Policy. Please review the destination websites' privacy policies before submitting personal data on those sites. Whilst we try to link only to sites that share our high standards and respect for privacy, we are not responsible for the content, security, or privacy practices employed by other sites.

## **14. Do we change this privacy policy?**

We regularly review this Privacy Policy and will post any updates to it on this webpage. This Privacy Policy was last updated on 11 March 2021.



# Compliance Confirmation

# Compliance Confirmation

## 1. Policy Compliance

I have read and understand the policies and requirements set out in **Managing Risk @ KPMG** and agree to comply with the policies/guidelines described within including:

- Swiss Code of Conduct – Ethical culture and KPMG
- Independence Considerations
- Anti Bribery, Corruption and Fraud
- Insider Trading
- Privacy
- Whistleblowing
- Acceptable Use of Assets

## 2. Independence - Appointments

Your answers to the below questions are needed to enable KPMG to meet our professional auditor independence and conflicts of interest requirements, and to identify and pro-actively manage any matters of concern that may arise.

b) Are you currently a Director, Company secretary, Board member of any:

- Company;
- Trading entity;
- Not- For-Profit/Charity; or

|                                                                                                                   |     |    |
|-------------------------------------------------------------------------------------------------------------------|-----|----|
| involved in any entity's financial accounting/ monitoring/<br>reporting/ oversight (e.g. CEO, CFO or equivalent)? | Yes | No |
|-------------------------------------------------------------------------------------------------------------------|-----|----|

|                                                         |                          |                          |
|---------------------------------------------------------|--------------------------|--------------------------|
| If yes, please provide brief details for KPMG to check: | <input type="checkbox"/> | <input type="checkbox"/> |
|---------------------------------------------------------|--------------------------|--------------------------|

| Entity Name | Role  |
|-------------|-------|
| <hr/>       | <hr/> |
| <hr/>       | <hr/> |
| <hr/>       | <hr/> |

# Compliance Confirmation

c)

If you have answered “Yes” to Question b), are any of the entities with which you are involved an audit client of KPMG?

Yes

No

Don’t Know

If yes, please provide brief details for KPMG to check

☐

☐

☐

| Company Name | Role |
|--------------|------|
| <div></div>  |      |
| <div></div>  |      |

d)

Are there any other services or relationships with any KPMG audit client of which you are aware that you wish to bring to our attention or to clarify with us?

Yes

No

If yes, please provide brief details for us to check:

☐

☐

# Compliance Confirmation

### 3. Declaration

I declare the above responses are, to the best of my knowledge and belief, true and correct and I agree to comply with the policies described in the **Managing Risk @ KPMG**.

Name: \_\_\_\_\_

Signature: \_\_\_\_\_

Contracting entity (legal name): \_\_\_\_\_

Contact number: \_\_\_\_\_

Contact email: \_\_\_\_\_

Date confirmation signed: \_\_\_\_\_

If there are any responses that you are unsure of, or would like further assistance with, please provide sufficient details for us to investigate, or contact Ethics & Independence Partner (Tara Collins Vieli at [taracollins@kpmg.com](mailto:taracollins@kpmg.com) or +41 58 249 54 41)

